

TP2, eleve : Threat modeling (HARD MODE)

- Jour 1 - Duree : ~1h45 - Dossier : `jour1-threatmodel/`
- Atelier en equipes. Pas de conteneur. Aucun DFD fourni : vous le reconstruisez.

Contexte

Comme en vrai : on vous remet un dossier realiste et imparfait (spec d'API, compose, ADR, user stories). A vous d'en deduire l'architecture, les limites de confiance, et les menaces. Puis une passe adverse viendra challenger votre travail.

Le dossier a analyser (`dossier/`)

- `openapi.yaml` : la spec de l'API (des endpoints trahissent des choix discutables).
- `docker-compose.reference.yaml` : les services, reseaux, dependances.
- `user-stories.md` : parcours + exigences non fonctionnelles.
- `adr/` : 3 decisions d'architecture, chacune avec des choix a challenger.

Demarche (4 questions de Shostack)

1. Qu'est-ce qu'on construit ? -> reconstituez le DFD + limites de confiance.
2. Qu'est-ce qui peut mal tourner ? -> STRIDE + arbres d'attaque sur 2 joyaux.
3. Qu'est-ce qu'on fait ? -> mitigations priorisees + risque residuel.
4. A-t-on bien travaille ? -> passe adverse.

Livrables (dans `livrables/`)

1. DFD reconstruit + limites de confiance
2. STRIDE par element
3. Arbres d'attaque (PII clients, capacite admin)
4. Cas de mesusage
5. Cotation du risque justifiee (DREAD ou vraisemblance x impact)
6. Mitigations + risque residuel
7. Prediction scellee : vos 8 vulns anticipees pour le CTF de demain

Deux mecaniques qui corsent (voir `passe-adverse.md`)

- Passe adverse : vous echangez vos mitigations avec une autre equipe qui tente de les contourner.

- Prediction scellée : vos 8 vulns anticipés seront confrontés au CTF du Jour 2.

Ce qu'on attend d'un bac+4

- Reconstituer l'archi depuis des sources hétérogènes.
- Reperer les limites de confiance NON évidentes (service IA a outils, appels serveur-a-serveur, API "interne" exposée, métadonnées cloud, cle JWT partagée, file Redis sans auth, bucket a noms prévisibles, compte DB unique).
- Raisonner CHEMINS d'attaque (enchaînements), pas menaces isolées.
- Prioriser et assumer un risque résiduel.

Livrable final

Les 7 livrables remplis + la fiche de contournement recue/produite lors de la passe adverse.